ISA/IEC 62443-3-3 / 4-2 • SL-3 TESTING CHEAT SHEET

Rockwell Automation Allen-Bradley CompactLogix 5380 (5069-L3xx/L4xx) · Component type: **Embedded Device (EDR) - PLC/PAC** · Target SL = SL 3

Where to work	**Studio 5000 Logix Designer** (project .ACD; Controller Properties › Security). **FactoryTalk Administration Console** & Security. **FactoryTalk Policy Manager** + **FactoryTalk System Services** (CIP Security CA). Controller **keyswitch** RUN/REM/PROG; SD card; embedded Ethernet web page.
Interfaces / ports	EtherNet/IP explicit **TCP 44818**; CIP class-1 I/O **UDP 2222**; **CIP Security 2221 (DTLS)**; embedded web **80/443**; **SNMP 161** (on comms modules).
Firmware note	CIP Security requires controller firmware **v33+** and Studio 5000 **v33+** with FactoryTalk System Services (CA) + Policy Manager. Confirm catalog **5069-L3xx / L4xx** and firmware rev in Who Active. CompactLogix has **dual embedded Ethernet** ports (DLR/linear); no controller redundancy.
How to read	Default read-only (Who Active / read-only online). Each row = native how-to + external-tool validation + pass criteria. Write/exploit tools = **isolated/representative env + written authorization**.

Project capture & evidence handling - pull BOTH the .ACD and the .L5X

Do this BEFORE working the checklist - you need BOTH files, not just the ACD upload. Going through the config screens and the logic screens requires the exported **.L5X** in addition to the native **.ACD**:
1. Upload the RUNNING program first. In Studio 5000 Logix Designer set the comms path in FactoryTalk Linx / RSLinx (**Who Active**), go **online** with the controller and **Upload** - the copy on disk may be stale versus what is actually executing. Record the controller catalog, **firmware revision**, slot, and the FactoryTalk user who may upload/download.
2. Save the .ACD (File › Save / Save As). This is the authoritative, version-matched project - needed to go back online and to see everything natively (rung/tag descriptions, AOI source, faceplates). It is **locked to the Studio 5000 major version** and is **not** human-readable or diffable.
3. ALSO export the .L5X (File › Save As → Save as type: **Logix Designer XML File (*.L5X)**, full project). The L5X is **version-independent XML** you can open, search and **diff** without the exact Studio 5000 build - this is what you actually walk for the **config screens** (Controller Properties, Module/I-O tree, Tasks/Programs, comms, controller security) and the **logic screens** (routines - ladder/FBD/ST, Add-On Instructions, tags). Grabbing only the ACD is how reviews get stuck.
4. Grab the supporting evidence too: tag + documentation export (Tools/Tags → Export to **.CSV**), the I-O module tree, Controller Properties screenshots, and on **GuardLogix** the **Safety Signature** (ID + date). Note the FactoryTalk Security roles for attribution - the controller log alone lacks user identity.
5. Name + protect the files (keep BOTH). `<site>_<zone>_<assetTag>_<catalog>_slot<n>_fw<rev>_<YYYYMMDD-HHMM>_<initials>` with the matching **.ACD** and **.L5X** extensions (and the .CSV tag export). SHA-256 hash each; store **only** on the encrypted evidence share; follow the project retention/classification policy; never email in cleartext. **Why both:** the ACD is authoritative but unusable without the matching Studio 5000 version and cannot be diffed; the L5X is the portable, reviewable, diffable record you build the checklist findings from.

FR 1 — Identification & Authentication Control (IAC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 1.1	Human user I&A	Studio 5000 › **Controller Properties › Security**: set **Security Authority** to the FactoryTalk Security server (with SNN, "bind to authority") and require authentication/authorization; assign **Permission Sets** so only authorized FT users can go online/download/edit. In **FactoryTalk Administration Console** confirm named/Windows-linked accounts (no shared). **Test:** attempt online/download as an unauthorized FT user -> denied. **Ext. tools:** FactoryTalk Admin Console (user/policy review); RSLinx / FactoryTalk Linx **Who Active** (enumerate access paths); ReadOnlyEnum.	All engineering access (online/download/edit/mode) requires FT authentication; unauthorized users denied; no anonymous CIP path to program.	Needs FactoryTalk Security bound. Controller-local only = Partial + compensating (segmentation + CIP Security).
SR/CR 1.2	Device & process I&A	In **FactoryTalk Policy Manager**, place the controller in a **Zone** and require a **Conduit** with certificate-based **Authentication** (+ Integrity); FactoryTalk System Services (CA) issues the device certificate; deploy the model. **Test (isolated):** connect an un-provisioned CIP client and confirm rejection. **Ext. tools:** Wireshark (enip/cip filter — confirm **DTLS/TLS**, not cleartext); pycomm3 / pylogix (isolated: unauthenticated CIP read -> expect refused); **openssl** (verify device cert chains to FT CA); Nmap --script enip-info -p 44818.	Only CIP-Security-provisioned peers connect; unauthenticated CIP rejected; conduit traffic is DTLS/TLS.	FW v33+. Native CIP without CIP Security is unauthenticated -> residual risk + segmentation.

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 1.3	Account management	**FactoryTalk Administration Console › Users and Groups**: review FT / Windows-linked accounts and group membership; remove/disable unused and default accounts; map least-privilege FT groups to the controller Permission Sets. The controller binds to the FT Directory via the **Security Authority** so accounts are centrally managed. **Ext. tools:** FactoryTalk Admin Console (account/group review); AssetCentre (account audit).	Named, least-privilege, centrally-managed accounts; no shared/default/orphaned accounts.	
SR/CR 1.4	Identifier management	Confirm unique FT user identifiers (no reuse) and that the controller Security Authority is bound with a unique **Security Network Number (SNN)** in **Controller Properties › Security**; identifiers managed over their lifecycle in FT. **Ext. tools:** FactoryTalk Admin Console; Logix Designer (SNN / Security Authority).	Unique user + device identifiers; SNN bound; no reuse.	
SR/CR 1.5	Authenticator management	FactoryTalk Directory › **policies** (or Windows-linked accounts) manage credential lifecycle; in **Policy Manager** confirm certificate issuance / renewal / **revocation** works and CA is protected. Confirm any default/vendor credentials are removed. **Ext. tools:** FactoryTalk Admin Console (policy review); openssl (cert validity/expiry, revocation).	Authenticators (FT accounts + device certs) initialized, protected, and revocable; no defaults remain.	Controller has no local user DB; identity is FT/AD + certs.
SR 1.6	Wireless Access Management	**N/A.** No wireless interface on this device; wireless access is managed at the network layer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 1.7	Strength of password auth	Password strength is enforced by **FactoryTalk Security** / the Windows domain (length, complexity, expiry, history) — review the FT Directory security policy / AD GPO. The controller itself holds no password. **Ext. tools:** AD / GPO review; FactoryTalk policy review.	Strong password policy enforced upstream (FT/AD) per SL-3.	If workgroup FT only, policy may be weak -> compensating control.
SR/CR 1.8	PKI certificates	For CIP Security, **FactoryTalk System Services** is the CA. In **FactoryTalk Policy Manager** review the controller device certificate (issued, valid, not expired) and confirm the CA private key is protected; renew/replace as needed. **Ext. tools:** FactoryTalk Policy Manager (cert view); openssl (validity/chain).	Valid CA-issued device certs; CA protected; renewal/revocation in place.	
SR/CR 1.9	Strength of public key auth	Confirm the CIP Security certificates use strong keys/algorithms per ODVA (ECC / RSA >=2048) via FactoryTalk System Services; no weak or expired certificates. **Ext. tools:** openssl x509 (key/algorithm parameters).	Strong certificate crypto; weak/expired certs absent.	
SR/CR 1.10	Authenticator feedback	Confirm the Logix Designer / FactoryTalk login dialogs **mask password entry** (no cleartext echo) on every interface used to reach the controller. **Ext. tools:** Visual verification at each login.	Authenticators obscured during entry on all interfaces.	
SR/CR 1.11	Unsuccessful login attempts	Account lockout is enforced by **FactoryTalk Security / Windows account-lockout policy** (or AD), not by the controller. Confirm lockout threshold/duration in the FT/AD policy. **Ext. tools:** Hydra/Medusa (ISOLATED, authorized) against the FT/Studio login to confirm lockout — or to record that direct CIP has none.	Lockout triggers on FT/AD; direct-CIP has no lockout -> record Partial + compensating (CIP Security + segmentation).	Known gap at the controller; plan FT/AD lockout.
SR/CR 1.12	System use notification	The controller has no logon banner; enforce the approved use-notification banner on the Studio 5000 / FactoryTalk **engineering workstation** (Windows interactive-logon banner via GPO) as the compensating control. **Ext. tools:** EWS GPO / secpol review; login visual check.	Approved banner shown on the engineering workstation (Partial if no controller-level banner).	Compensating (EWS).
SR 1.13	Access via untrusted networks	Confirm the controller is **not directly reachable** (44818/2222) from untrusted segments; cross-zone access goes through a CIP Security conduit and remote access via a hardened jump host + MFA. Review cell/area-zone firewall rules. **Ext. tools:** Nmap from each segment (44818/2222 reachability); firewall-rule review; jump-host/VPN log review.	No direct untrusted-network reachability; brokered, authenticated, monitored remote access only.	Segmentation + IDMZ (CPwE).

FR 2 — Use Control (UC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 2.1	Authorization enforcement	Controller Properties › Security › **Permission Sets**: verify per-action rights (go online, download, change mode, edit logic, modify security) are mapped to FT security groups with least privilege. **Test:** a low-privilege FT user cannot download / change mode / disable security. **Ext. tools:** FactoryTalk Admin Console (permission-set / group review); Studio 5000 (attempt as low-priv user).	Least privilege enforced per action; privileged actions denied to non-authorized users.	
SR/CR 2.2	Wireless Use Control	**N/A.** No wireless interface on this device; wireless access is managed at the network layer.	N/A - justification recorded (not assessed as a control).	N/A
SR 2.3	Use control for portable/mobile devices	Control removable media at the controller (secure/remove the **SD card**; load only authorized images) and enforce a **USB / removable-media policy** on the Studio 5000 EWS. Confirm no unauthorized portable device can program the controller. **Ext. tools:** Physical inspection; EWS USB/removable-media policy review.	SD/USB controlled at the controller and the EWS; only authorized media used.	
SR/EDR 2.4	Mobile code	No general-purpose mobile code executes on the controller; confirm only **signed modules / trusted AOIs** run and there is no path to load untrusted add-on content or scripts. **Ext. tools:** Module / Add-On Instruction review; ControlFLASH Plus (signature).	Only signed/trusted code; no untrusted mobile-code path.	EDR-specific.
SR/CR 2.5	Session lock	No controller-side idle lock; enforce **workstation lock** (Windows inactivity / screen saver) and FactoryTalk session policy on the EWS running Studio 5000. **Ext. tools:** Manual idle test on the EWS.	EWS auto-locks on inactivity; controller change requires re-auth.	Compensating (workstation-level).
SR/CR 2.6	Remote session termination	Enumerate active CIP / engineering connections with **RSLinx / FactoryTalk Linx Who Active** and confirm sessions can be terminated; the controller closes idle connections via connection inactivity/timeout. **Ext. tools:** Who Active (view / terminate connections).	Remote sessions can be terminated on demand and on inactivity timeout.	
SR/CR 2.7	Concurrent session control	Confirm concurrent programming/edit sessions are controlled — FactoryTalk Security + Logix online-edit locking prevent conflicting simultaneous edits; monitor concurrent CIP connections in Who Active. **Ext. tools:** Who Active; FactoryTalk Security review.	Concurrent privileged/edit sessions limited or monitored.	
SR/CR 2.8	Auditable events	Review the **Controller Log** (Controller Properties › **Controller Log**) — records keyswitch/mode changes, downloads, firmware, faults, and (with FT bound) the user. Enable **FactoryTalk AssetCentre** audit & change management for user/terminal attribution and change detection (Audit Value / SNN). **Test:** change mode -> confirm a log entry. **Ext. tools:** FactoryTalk AssetCentre (audit by user/device/terminal); Controller Log export.	Security-relevant events recorded with timestamp; user attribution via AssetCentre.	
SR/CR 2.9	Audit storage capacity	The **Controller Log** is a fixed-size rolling buffer (oldest overwritten) — offload to **FactoryTalk AssetCentre** for retention; confirm the AssetCentre audit database is sized, retained, and alerts before reaching capacity. **Ext. tools:** AssetCentre (retention / capacity-alert review).	Audit retention sized and offloaded; alert before overflow.	
SR/CR 2.10	Response to audit processing failures	Confirm FactoryTalk AssetCentre **alerts on audit-collection failure** and that Controller-Log overwrite behavior is understood; audit failures are surfaced, not silently dropped. **Ext. tools:** AssetCentre alerting configuration review.	Audit-processing failures alerted with a defined response.	
SR/CR 2.11	Timestamps	Confirm controller time source: **CIP Sync (IEEE 1588/PTP)** or NTP via a comms module / GPS; check WallClockTime and that logs use synced time. **Ext. tools:** Wireshark (PTP/NTP); GSV WallClockTime review.	Accurate synchronized time; log timestamps consistent.	
SR/CR 2.12	Non-repudiation	**FactoryTalk AssetCentre** + FT Security tie configuration changes to a named user (the Controller Log alone lacks user identity). Verify change records show who/what/when. **Ext. tools:** AssetCentre change reports.	Every config change attributable to a named user.	Requires AssetCentre + FT bound.
EDR 2.13	Physical diagnostic & test interfaces	Control the **USB and SD-card** interfaces: SD used only for authorized image store/restore; keep the controller in a locked panel; disable/limit the embedded web diagnostic page. **Ext. tools:** Physical inspection; ReadOnlyEnum (interface enumeration).	Physical/diagnostic interfaces controlled; SD/USB access restricted; panel locked/sealed.	EDR-specific.

FR 3 — System Integrity (SI)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 3.1	Communication integrity	In Policy Manager confirm the conduit enforces **Integrity** (HMAC) and, where required, **Confidentiality**; verify no critical CIP conduit runs cleartext. Capture and confirm DTLS/TLS. **Ext. tools:** Wireshark (confirm CIP Security DTLS/TLS on 2221; no plain 44818 for in-scope conduits).	Integrity (and confidentiality where needed) enforced on in-scope conduits; tampering detected.	FW v33+.
SR/EDR 3.2	Protection from malicious code	Confirm firmware is **digitally signed** (5580 rejects unsigned/mismatched firmware); source firmware only from Rockwell PCDC; restrict who can run **ControlFLASH Plus**; use **Firmware Supervisor**. No arbitrary code execution path. **Ext. tools:** ControlFLASH Plus (signature verify on flash); PCDC checksum cross-check.	Only signed Rockwell firmware loads; unsigned/altered firmware rejected; flashing restricted.	EDR-specific.
SR/CR 3.3	Security functionality verification	After any change, re-verify the security settings (Security tab, Permission Sets, CIP Security model) and compare the .ACD against the baseline; use AssetCentre change detection. **Ext. tools:** FactoryTalk AssetCentre (compare/verify); Logix Designer compare tool.	Documented re-verification; settings match the hardening baseline.	
SR/CR 3.4	Software & information integrity	Protect logic with **License-Based Source Protection** (or source key) and enable **change detection** (Controller Properties › Advanced › **Audit Value** / Change Detection + SNN). **Test:** modify offline and confirm the change is detected. **Ext. tools:** AssetCentre (audit value monitoring); Logix compare.	Program integrity protected; unauthorized change detected via Audit Value/SNN.	
SR/CR 3.5	Input validation	Confirm the controller tolerates malformed EtherNet/IP/CIP frames without faulting. **ISOLATED only:** fuzz EtherNet/IP and observe controller/connection health. **Ext. tools:** ENIP/CIP fuzzer (ISOLATED); Wireshark; controller diagnostics/GSV fault review.	No crash, major fault, or loss of control on malformed input.	Do NOT fuzz production.
SR/CR 3.6	Deterministic output	Verify the configured fault/safe-state behavior: output-module **Program-mode and Fault-state** settings (hold-last-state vs safe-state), controller **fault routines**, and connection-loss behavior, so outputs assume a defined safe state on fault or comm loss. **Ext. tools:** Logix Designer (output-module config + fault routines review).	Outputs go to a defined/fail-safe state on fault or communication loss.	
SR/CR 3.7	Error handling	Confirm major/minor **fault handling** (fault routines, GSV FAULTLOG/status) so errors are handled gracefully without loss of control or information leakage; exercise a controlled fault in an isolated environment. **Ext. tools:** Logix Designer (fault routines); GSV fault status; (isolated) fault injection.	Graceful fault handling; no crash, unsafe state, or info leak.	
SR/CR 3.8	Session integrity	Where CIP Security is applied, the DTLS/TLS session protects against replay/hijack. Confirm sessions are protected and old sessions cannot be replayed. **Ext. tools:** Wireshark (session/replay inspection, isolated).	Sessions integrity-protected; replay/hijack prevented on protected conduits.	
SR/CR 3.9	Protection of audit information	The Controller Log is read-only via Logix (not user-editable); confirm the **FactoryTalk AssetCentre** audit database has access controls + integrity protection so audit records cannot be altered or deleted by unauthorized users. **Ext. tools:** AssetCentre DB access-control review.	Audit records protected from unauthorized read/modify/delete.	
EDR 3.10	Support for updates	Update firmware only with **ControlFLASH Plus** using Rockwell-**signed** firmware from the PCDC; the controller validates the firmware digital signature before accepting it; use **Firmware Supervisor** for controlled updates; roll back by reflashing a prior signed revision. **Ext. tools:** ControlFLASH Plus (signed update / verify); PCDC checksum cross-check.	Signed firmware updates only, with a controlled update + rollback path.	EDR-specific.
EDR 3.11	Physical tamper resistance/detection	Set the **keyswitch to RUN** in production (blocks remote program/mode change); keep the controller in a locked, sealed enclosure; secure/remove the **SD card**; the Controller Log records keyswitch/mode changes as tamper evidence. **Ext. tools:** Physical inspection; Controller Log (keyswitch/mode events).	Keyswitch in RUN; enclosure locked/sealed; SD secured; changes logged.	EDR-specific.
EDR 3.12	Provisioning product-supplier roots of trust	The controller accepts only **Rockwell-signed firmware** — the product-supplier root of trust that validates firmware authenticity; confirm the signing chain is intact and unsigned/altered firmware is rejected at load. **Ext. tools:** ControlFLASH Plus (signature verify); attempt unsigned image (isolated) -> rejected.	Supplier signing root intact; unsigned/altered firmware rejected.	EDR-specific.
EDR 3.13	Provisioning asset-owner roots of trust	For CIP Security, the asset owner's **FactoryTalk System Services** is the Certificate Authority (asset-owner root of trust); confirm the controller is enrolled to the asset owner's CA and device certificates are provisioned/managed in **FactoryTalk Policy Manager**. **Ext. tools:** FactoryTalk Policy Manager / System Services (CA + device enrollment).	Controller enrolled to the asset-owner CA; device certs provisioned/managed.	EDR-specific.

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
EDR 3.14	Integrity of the boot process	Confirm the controller **validates the digital signature/integrity of its firmware before execution** (signed-firmware boot integrity); no unsigned or tampered firmware runs. Capture firmware revision + signature status. **Ext. tools:** ControlFLASH Plus; controller diagnostics (firmware revision/signature).	Firmware integrity validated before execution; only signed firmware boots.	EDR-specific.

FR 4 — Data Confidentiality (DC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 4.1	Information confidentiality	Apply CIP Security **Confidentiality** to conduits carrying sensitive data; protect the .ACD with source protection; protect SD-card images. Confirm sensitive comms are encrypted. **Ext. tools:** Wireshark (confirm encryption on protected conduits).	Sensitive comms encrypted; project source and images protected.	
SR/CR 4.2	Information persistence	On decommission/re-use, clear controller memory and nonvolatile/SD storage, remove device certificates, and securely dispose. Confirm no residual program/creds. **Ext. tools:** Physical + Who Active verification post-wipe.	Memory/SD purged; certs removed; no residual sensitive data.	
SR/CR 4.3	Use of cryptography	CIP Security uses TLS/DTLS with ODVA-specified cipher suites (ECC/AES); verify certificate parameters and cipher strength via FactoryTalk System Services. **Ext. tools:** openssl (cert/key parameters); Wireshark (negotiated cipher).	Modern TLS/DTLS + strong ciphers; weak parameters absent.	

FR 5 — Restricted Data Flow (RDF)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 5.1	Network segmentation	Confirm the controller sits in a segmented cell/area zone (CPwE) with CIP Security zones/conduits and firewall/IDMZ boundaries; only required conduits cross zones. **Ext. tools:** Nmap from each zone (reachability); Policy Manager zone/conduit review.	Controller in a controlled segment; only defined conduits permitted.	
SR 5.2	Zone boundary protection	Verify a stateful/industrial firewall at the zone boundary restricts 44818/2222 and denies cross-zone traffic except approved conduits. **Ext. tools:** Nmap -p 44818,2222 across the boundary; firewall rule review.	Boundary enforces least-flow; unauthorized cross-zone denied.	
SR 5.3	General Purpose Person-to-Person Communication Restrictions	**N/A.** Embedded device has no general-purpose person-to-person communications (email/IM/web).	N/A - justification recorded (not assessed as a control).	N/A
SR 5.4	Application Partitioning	**N/A.** Single-purpose device; no separable applications to partition (handled at the host/SCADA layer).	N/A - justification recorded (not assessed as a control).	N/A

FR 6 — Timely Response to Events (TRE)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 6.1	Audit log accessibility	Confirm the Controller Log and AssetCentre audit/change records can be read/exported by authorized staff and forwarded to the SIEM. **Ext. tools:** AssetCentre reports/export; syslog forwarder.	Audit records accessible/exportable to authorized users; forwarded to SIEM.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 6.2	Continuous monitoring	Deploy passive OT monitoring (Claroty / Nozomi / Dragos) on the cell segment plus AssetCentre and syslog; monitor controller health/faults and CIP anomalies. **Ext. tools:** Passive OT monitor (SPAN/tap); syslog listener (nc -lu 514).	Monitoring/alerting active for the controller and its segment.	

FR 7 — Resource Availability (RA)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 7.1	Denial-of-service protection	Confirm EtherNet/IP connection limits and CIP overload protection; storm-control at the access switch; use system-level hot-standby / DLR resiliency where availability is critical. **ISOLATED:** load/flood test to confirm the controller keeps controlling. **Ext. tools:** Traffic generator / load test (ISOLATED); Wireshark; controller connection/CPU diagnostics.	Controller maintains control under load; connection limits/storm-control effective.	
SR/CR 7.2	Resource management	Monitor CPU/memory/connection usage (controller diagnostics / GSV TASK & connection objects); confirm connection caps prevent exhaustion. **Ext. tools:** GSV/diagnostic review; passive monitor.	Resource use bounded; no exhaustion under normal + peak.	
SR/CR 7.3	Control system backup	Save the **.ACD** project and store a controller image to **SD (nonvolatile memory)**; schedule **FactoryTalk AssetCentre Disaster Recovery** backups; verify backup integrity (hash). **Ext. tools:** AssetCentre DR; sha256sum of .ACD.	Recent verified .ACD + SD image + AssetCentre backup exist.	
SR/CR 7.4	Recovery & reconstitution	Test restore of firmware + .ACD + certificates onto a spare 5069-L3xx / L4xx; confirm redundancy failover where used. **Ext. tools:** ControlFLASH Plus + Studio 5000 (lab restore).	Restore validated on spare; RTO/RPO met; failover confirmed.	
SR 7.5	Emergency Power	**N/A.** Emergency/backup power is provided at the facility/UPS level, not the device; confirm the device retains its security state across a power transfer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 7.6	Network & security config settings	Document and baseline all controller security settings (Security tab, Permission Sets, CIP Security model, disabled services); capture in .ACD + AssetCentre; change-control changes. **Ext. tools:** AssetCentre baseline compare.	Settings documented, baselined, and change-controlled.	
SR/CR 7.7	Least functionality	Disable unused services: embedded **web (HTTP) page**, **SNMP** (or SNMPv3 only) on comms modules, unused CIP objects, and unused Ethernet ports; set the **keyswitch to RUN** in production. **Ext. tools:** Nmap (open services 80/443/161/44818); PortQry.	Only required services/ports enabled; web/SNMP disabled; keyswitch in RUN.	
SR/CR 7.8	Component inventory	Capture controller catalog, firmware rev, and module list via **Who Active** / RSLinx / AssetCentre for the asset inventory. **Ext. tools:** Who Active; AssetCentre inventory; ReadOnlyEnum.	Complete catalog/firmware/module inventory captured.	

External Test Tools — how to use

Tool / method	Verifies	How to use — steps / example	Constraints
Studio 5000 Logix Designer	Native security config & RBAC (1.1, 2.1, 3.4)	Open the .ACD read-only; review Controller Properties › Security (Security Authority, Permission Sets), Advanced (Audit Value), and Controller Log. Attempt privileged actions as a low-priv FT user.	Read-only online; least-priv FT account.
FactoryTalk Admin Console / Security	Accounts, groups, password & lockout policy (1.1, 1.5, 1.7, 1.11, 2.1)	Review FT Directory users/groups, permission sets, password policy, and account-lockout settings; confirm no shared/default accounts.	Read-only review.
FactoryTalk Policy Manager + System Services	CIP Security zones/conduits + CA (1.2, 3.1, 4.1, 4.3)	Review zones, conduits (Authentication/Integrity/Confidentiality), device certificates, and the CA; deploy/verify the model in a lab.	Changes in lab/representative env.

Tool / method	Verifies	How to use — steps / example	Constraints
FactoryTalk AssetCentre	Audit, change detection, backup/DR (2.8, 2.12, 3.3, 3.4, 7.3)	Review audit-by-user/terminal reports, Audit Value change detection, and scheduled Disaster Recovery backups; compare to baseline.	Read/compare baselines.
RSLinx / FactoryTalk Linx (Who Active)	Inventory & connection enumeration (7.8, 1.1)	Browse the network (Who Active) to enumerate controller catalog, firmware, modules, and active CIP connections.	Passive on production; TCP/UDP 44818, UDP 2222.
ControlFLASH Plus	Signed-firmware verify / update (3.2, 7.4)	Verify firmware signature during flash; source firmware from Rockwell PCDC and cross-check checksums.	Authorized maintenance window only.
Nmap (EtherNet/IP NSE)	Port/service exposure & segmentation (1.13, 5.1, 5.2, 7.7)	nmap -sT -p 44818,2222,80,443,161 -T2 <plc>; nmap --script enip-info -p 44818 <plc>. Scan from each zone to prove segmentation.	Tune timing (-T2) on production.
Wireshark / tcpdump	CIP integrity/crypto, comm integrity (1.2, 3.1, 4.1)	SPAN/tap capture; filter enip || cip; confirm in-scope conduits are DTLS/TLS (2221) and not cleartext 44818; inspect PTP/NTP.	Passive; SPAN/tap only.
openssl	CIP Security certificate inspection (1.5, 4.3)	Inspect the device certificate issued by FT System Services (subject/issuer/dates/key); confirm chain to the FT CA and validity.	Read-only.
pycomm3 / pylogix	Unauthenticated-CIP test (1.2)	From an un-provisioned client attempt a CIP read/write; with CIP Security enforced it must be refused.	ISOLATED/representative env; authorization.
PortQry / TCPing	CIP reachability (5.2, 7.7)	portqry -n <plc> -e 44818 to confirm reachability by segment.	Read-only reachability.
ReadOnlyEnum	Host/network/interface enumeration (2.13, 7.8)	Enumerate exposed services, ports, and interfaces supporting the controller read-only.	Needs read access; read-only.
Passive OT monitor (Claroty / Nozomi / Dragos)	Continuous monitoring & inventory (6.2, 7.8)	Passively observe the cell segment for asset inventory, CIP exposure, and anomalies.	Passive only.
EtherNet/IP fuzzer / traffic generator	Input validation & DoS resilience (3.5, 7.1)	Send malformed/high-rate EtherNet/IP frames and observe controller/connection health.	ISOLATED/non-production only; authorization.
Hydra / Medusa	FT/Studio lockout behavior (1.11)	Authorized repeated logins against the FactoryTalk/Studio login to confirm lockout triggers.	ISOLATED/authorized only.
Kali / Metasploit (ICS modules)	Exploitation proof (as authorized)	Validate exploitability of a specific finding in a mirror/lab environment only.	Mirror/lab; written authorization.

Controlled - Project Use · Independent Assurance Services · ISA/IEC 62443-3-3 / 4-2 · Product-specific companion to the 62443 assessment tool; confirm exact menu paths / CLI against the deployed firmware and the project hardening baseline. ISOLATED tools run only in a representative/lab environment with written authorization.